



Security Assessment Report

Static Application Security Testing & Code Assessment

PROJECT

Project Trail-01

SCAN NAME

Demo Scan-01

UPLOADED FILE

vulnerable.py

ASSESSMENT TYPE

Initial Assessment

LANGUAGE

python

ASSESSMENT DATE

6 October 2026

PREPARED BY

SecureCode Auditor Platform

CONFIDENTIAL

Document Control

Document Title	Security Assessment Report
Application	SecureCode Auditor
Project	Project Trail-01
Scan Name	Demo Scan-01
Uploaded File	vulnerable.py
Assessment Type	INITIAL
Scan ID	6ac3f805ad56ebd03c4ca70f
Programming Language	python
Scanner	SecureCode Auditor Platform
Assessment Date	6/10/2026, 12:48:29 am
Report Generated	6/10/2026, 7:55:57 pm
Report Version	1.0
Classification	CONFIDENTIAL

Table of Contents

- 1. Executive Summary
- 2. Assessment Overview
- 3. Assessment Methodology
- 4. Scope
- 5. Risk Summary
- 6. Findings Summary
- 7. Detailed Findings
 - 7.1 Critical Findings
 - 7.2 High Findings
 - 7.3 Medium Findings
 - 7.4 Low Findings
- 8. Remediation & Recommendations
- 9. Conclusion
- 10. References
- 11. Appendix

1. Executive Summary

This security assessment was automatically performed using the SecureCode Auditor platform to identify, classify, and provide remediation guidance for security weaknesses within the assessed source code.



Overall Security Risk: CRITICAL

The assessed codebase contains critical severity findings that pose an immediate and severe threat to application security. Immediate prioritized remediation is mandatory to prevent potential compromise.

2. Assessment Overview

Project	Project Trail-01
Scan Name	Demo Scan-01
Uploaded File	vulnerable.py
Language	python
Scanner	SecureCode Auditor Platform
Scan Type	INITIAL
Assessment Date	6/10/2026, 12:48:29 am

3. Assessment Methodology

The security assessment follows a rigorous lifecycle leveraging both static analysis and AI-assisted contextual validation:

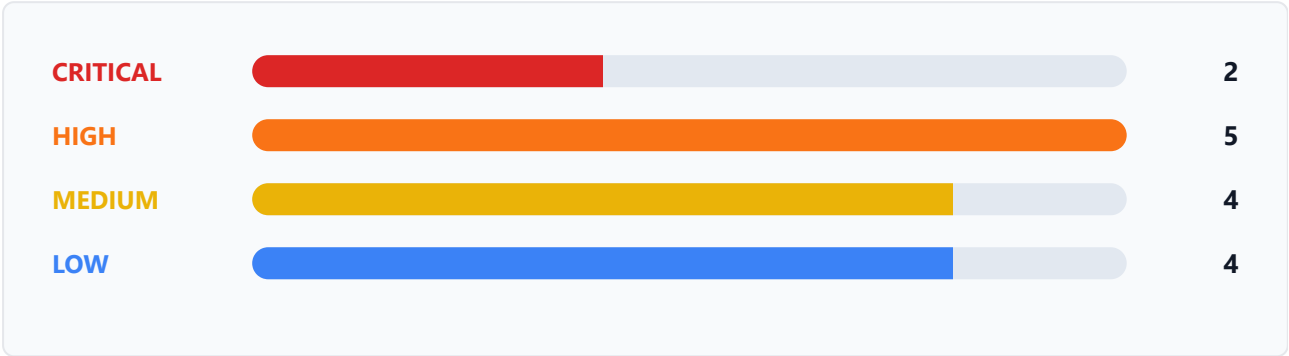
- 1. **Static Analysis:** The source code is scanned using industry-standard static application security testing (SAST) engines to identify vulnerable patterns.
- 2. **Vulnerability Identification:** Findings are mapped to standard frameworks (CWE, OWASP).
- 3. **AI-Assisted Analysis:** Validated findings are analyzed by an advanced AI model to determine context, root cause, and precise secure code remediation.
- 4. **Manual Security Review:** Human security analysts review critical findings to validate True/False positives and assess business risk.
- 5. **Reporting:** A comprehensive assessment report is compiled detailing all evidence and actionable remediation steps.

4. Scope

The scope of this assessment includes the source code provided to the SecureCode Auditor platform during the initiation of the scan.

Project Scope	Project Trail-01
Target Language	python
Environment	Static Source Code

5. Risk Summary



6. Findings Summary

ID	Finding	Severity	Status	CWE	Review
F-001	SQL String Concatenation	CRITICAL	OPEN	CWE-89	N/A
F-002	Dangerous subprocess Usage	CRITICAL	OPEN	CWE-78	N/A
F-003	start_process_with_a_shell	HIGH	OPEN	B605	N/A
F-004	subprocess_popen_with_shell_equals_true	HIGH	OPEN	B602	N/A
F-005	hashlib	HIGH	OPEN	B324	N/A
F-006	request_with_no_cert_validation	HIGH	OPEN	B501	N/A
F-007	Weak Encryption	HIGH	OPEN	CWE-327	N/A

ID	Finding	Severity	Status	CWE	Review
F-008	hardcoded_sql_expressions	MEDIUM	OPEN	B608	N/A
F-009	blacklist	MEDIUM	OPEN	B301	N/A
F-010	request_without_timeout	MEDIUM	OPEN	B113	N/A
F-011	MD5	MEDIUM	OPEN	CWE-327	N/A
F-012	blacklist	LOW	OPEN	B404	N/A
F-013	blacklist	LOW	OPEN	B403	N/A
F-014	hardcoded_password_string	LOW	OPEN	B105	N/A
F-015	hardcoded_password_string	LOW	OPEN	B105	N/A

7. Detailed Findings

F-001

SQL String Concatenation CRITICAL

Status	OPEN	Scanner	Bandit
Rule ID	SCA-SQL-001	File	vulnerable.py
CWE	CWE-89	Line	26
OWASP	A03 Injection		

Description

Detect SQL queries constructed using untrusted input.

Vulnerable Code

```
query = "SELECT * FROM users WHERE username = '" + username + "'"
```

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

- [R1]** **CWE-89 — CWE-89**
External Reference
<https://cwe.mitre.org/data/definitions/89.html>
- [R2]** **OWASP Category — A03 Injection**
External Reference
<https://owasp.org/>

F-002

Dangerous subprocess Usage **CRITICAL**

Status	OPEN	Scanner	Bandit
Rule ID	SCA-CMD-002	File	vulnerable.py
CWE	CWE-78	Line	18
OWASP	A03 Injection		

Description

Detect subprocess execution with shell=True and untrusted input.

Vulnerable Code

```
subprocess.call("cat " + filename, shell=True)
```

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

- [R3]** **CWE-78 — CWE-78**
External Reference
<https://cwe.mitre.org/data/definitions/78.html>
- [R2]** **OWASP Category — A03 Injection**
External Reference
<https://owasp.org/>

F-003

start_process_with_a_shell **HIGH**

Status	OPEN	Scanner	Bandit
Rule ID	B605	File	vulnerable.py
CWE	B605	Line	14
OWASP	B605		

Description

Starting a process with a shell, possible injection detected, security issue.

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-004

subprocess_popen_with_shell_equals_true HIGH

Status	OPEN	Scanner	Bandit
Rule ID	B602	File	vulnerable.py
CWE	B602	Line	18
OWASP	B602		

Description

subprocess call with shell=True identified, security issue.

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-005

hashlib HIGH

Status	OPEN	Scanner	Bandit
Rule ID	B324	File	vulnerable.py
CWE	B324	Line	35
OWASP	B324		

Description

Use of weak MD5 hash for security. Consider usedforsecurity=False

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-006

request_with_no_cert_validation HIGH

Status	OPEN	Scanner	Bandit
Rule ID	B501	File	vulnerable.py
CWE	B501	Line	40
OWASP	B501		

Description

Call to requests with verify=False disabling SSL certificate checks, security issue.

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-007

Weak Encryption **HIGH**

Status	OPEN	Scanner	Bandit
Rule ID	SCA-CRYPTO-005	File	vulnerable.py
CWE	CWE-327	Line	29
OWASP	A02 Cryptographic Failures		

Description

Detect DES, 3DES, RC4, ECB and other inappropriate cryptographic configurations.

Vulnerable Code

```
# 5. Insecure deserialization
```

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

- [R4]** **CWE-327 — CWE-327**
External Reference
<https://cwe.mitre.org/data/definitions/327.html>
- [R2]** **OWASP Category — A03 Injection**
External Reference
<https://owasp.org/>

F-008

hardcoded_sql_expressions **MEDIUM**

Status	OPEN	Scanner	Bandit
Rule ID	B608	File	vulnerable.py
CWE	B608	Line	26
OWASP	B608		

Description

Possible SQL injection vector through string-based query construction.

Security Impact

Confidence: LOW

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-009

blacklist MEDIUM

Status	OPEN	Scanner	Bandit
Rule ID	B301	File	vulnerable.py
CWE	B301	Line	31
OWASP	B301		

Description

Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-010

request_without_timeout MEDIUM

Status	OPEN	Scanner	Bandit
Rule ID	B113	File	vulnerable.py
CWE	B113	Line	38
OWASP	B113		

Description

Call to requests without timeout

Security Impact

Confidence: LOW

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-011

MD5 MEDIUM

Status	OPEN	Scanner	Bandit
Rule ID	SCA-CRYPTO-001	File	vulnerable.py
CWE	CWE-327	Line	35
OWASP	A02 Cryptographic Failures		

Description

Use of MD5 hash algorithm.

Vulnerable Code

```
hashed = hashlib.md5(password.encode()).hexdigest()
```

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

- [R4]** **CWE-327 — CWE-327**
External Reference
<https://cwe.mitre.org/data/definitions/327.html>
- [R2]** **OWASP Category — A03 Injection**
External Reference
<https://owasp.org/>

F-012

blacklist **LOW**

Status	OPEN	Scanner	Bandit
Rule ID	B404	File	vulnerable.py
CWE	B404	Line	2
OWASP	B404		

Description

Consider possible security implications associated with the subprocess module.

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

Summary

The code imports or uses the `subprocess` module, which can be a security risk if used to execute external commands with unsanitized input.

Why It Is Vulnerable

The `subprocess` module in Python allows the execution of external processes. The finding B404 is a general warning about the use of this module. The vulnerability arises when `subprocess` functions (like `call`, `run`, `Popen`) are used with `shell=True` or when command arguments are constructed using string concatenation or formatting with user-controlled data. This can lead to command injection if an attacker can manipulate the input to execute arbitrary system commands.

Root Cause

The use of the `subprocess` module without ensuring that all inputs are strictly validated and that `shell=True` is avoided. The root cause is the potential for command injection due to improper input handling when executing external processes.

Recommendation

1. Avoid using `shell=True` in `subprocess` calls. 2. Pass command arguments as a list to `subprocess` functions to prevent shell interpretation. 3. Validate and sanitize all user inputs before using them in command arguments. 4. Use `shlex.quote()` if shell execution is absolutely necessary, but prefer list-based arguments. 5. Consider using higher-level libraries that abstract away command execution if possible.

Secure Code Example

```
import subprocess

# Insecure: Using shell=True with user input
# user_input = input("Enter command: ")
# subprocess.call(f"echo {user_input}", shell=True)

# Secure: Using list arguments and avoiding shell=True
user_input = "hello world"
subprocess.run(["echo", user_input], check=True)
```

REFERENCES

- [R5]** docs.python.org/3/library/subprocess.html
External Reference
<https://docs.python.org/3/library/subprocess.html>
- [R6]** bandit.readthedocs.io/en/latest/plugins/b404_subprocess.html
External Reference
https://bandit.readthedocs.io/en/latest/plugins/b404_subprocess.html
- [R2]** OWASP Category — A03 Injection
External Reference
<https://owasp.org/>

F-013

blacklist **LOW**

Status	OPEN	Scanner	Bandit
Rule ID	B403	File	vulnerable.py
CWE	B403	Line	3
OWASP	B403		

Description

Consider possible security implications associated with pickle module.

Security Impact

Confidence: HIGH

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-014

hardcoded_password_string LOW

Status	OPEN	Scanner	Bandit
Rule ID	B105	File	vulnerable.py
CWE	B105	Line	9
OWASP	B105		

Description

Possible hardcoded password: 'Admin@123'

Security Impact

Confidence: MEDIUM

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

F-015

hardcoded_password_string LOW

Status	OPEN	Scanner	Bandit
Rule ID	B105	File	vulnerable.py
CWE	B105	Line	34
OWASP	B105		

Description

Possible hardcoded password: 'mypassword'

Security Impact

Confidence: MEDIUM

AI-ASSISTED SECURITY ANALYSIS

AI analysis was not generated for this finding.

REFERENCES

[R2] OWASP Category — A03 Injection

External Reference

<https://owasp.org/>

8. Remediation & Recommendations

ID	Severity	Recommended Action
F-001	CRITICAL	Use parameterized queries instead of string concatenation.
F-002	CRITICAL	Never use shell=True with untrusted input.
F-003	HIGH	Review the code and consult Bandit documentation for B605
F-004	HIGH	Review the code and consult Bandit documentation for B602
F-005	HIGH	Review the code and consult Bandit documentation for B324
F-006	HIGH	Review the code and consult Bandit documentation for B501
F-007	HIGH	Use authenticated encryption modes like AES-GCM.
F-008	MEDIUM	Review the code and consult Bandit documentation for B608
F-009	MEDIUM	Review the code and consult Bandit documentation for B301
F-010	MEDIUM	Review the code and consult Bandit documentation for B113
F-011	MEDIUM	Use strong hashing algorithms like SHA-256 or SHA-3.
F-012	LOW	1. Avoid using `shell=True` in `subprocess` calls. 2. Pass command arguments as a list to `subprocess` functions to prevent shell interpretation. 3. Validate and sanitize all user inputs before using them in command arguments. 4. Use `shlex.quote()` if shell execution is absolutely necessary, but prefer list-based arguments. 5. Consider using higher-level libraries that abstract away command execution if possible.
F-013	LOW	Review the code and consult Bandit documentation for B403
F-014	LOW	Review the code and consult Bandit documentation for B105

ID	Severity	Recommended Action
F-015	LOW	Review the code and consult Bandit documentation for B105

9. Conclusion

The assessment of **Project Trail-01** resulted in the identification of **15** vulnerabilities, resulting in an overall risk rating of **CRITICAL**.

The assessed codebase contains critical severity findings that pose an immediate and severe threat to application security. Immediate prioritized remediation is mandatory to prevent potential compromise.

It is strongly recommended that the development team reviews the detailed findings in Section 7 and applies the remediation steps outlined in Section 8. Critical and High severity findings should be prioritized in the immediate sprint to minimize organizational risk. Upon completion of remediation efforts, a retest scan should be performed to validate the integrity of the implemented fixes.

10. References

Reference Traceability

Finding	References
F-001	[R1], [R2]
F-002	[R3], [R2]
F-003	[R2]
F-004	[R2]
F-005	[R2]
F-006	[R2]
F-007	[R4], [R2]
F-008	[R2]
F-009	[R2]
F-010	[R2]
F-011	[R4], [R2]
F-012	[R5], [R6], [R2]
F-013	[R2]
F-014	[R2]
F-015	[R2]

Master Reference Registry

[R1] CWE-89 — CWE-89

Source: External Reference

<https://cwe.mitre.org/data/definitions/89.html>

Used by: F-001

[R2] OWASP Category — A03 Injection

Source: External Reference

<https://owasp.org/>

Used by: **F-001, F-002, F-003, F-004, F-005, F-006, F-007, F-008, F-009, F-010, F-011, F-012, F-013, F-014, F-015**

[R3] CWE-78 — CWE-78

Source: External Reference

<https://cwe.mitre.org/data/definitions/78.html>

Used by: **F-002**

[R4] CWE-327 — CWE-327

Source: External Reference

<https://cwe.mitre.org/data/definitions/327.html>

Used by: **F-007, F-011**

[R5] docs.python.org/3/library/subprocess.html

Source: External Reference

<https://docs.python.org/3/library/subprocess.html>

Used by: **F-012**

[R6] bandit.readthedocs.io/en/latest/plugins/b404_subprocess.html

Source: External Reference

https://bandit.readthedocs.io/en/latest/plugins/b404_subprocess.html

Used by: **F-012**

11. Appendix

A. Scan Metadata

Scan ID	6ac3f805ad56ebd03c4ca70f
Generated On	6/10/2026, 7:55:57 pm
Platform Engine	SecureCode Auditor Core

B. AI Model Information

The following AI models were utilized during the analysis of findings in this report:

- qwen/qwen3.8-27b

Note: AI analysis is strictly limited to static technical context and never introduces fabricated telemetry or false references.